Escuela Colombiana de Ingeniería Julio Garavito

# Taller – Security in the Data Lifecycle

Ángel Nicolas Cuervo Naranjo

Group

Javier Ivan Toquica Barrera

2026-1

# CASO DE ESTUDIO

**DataFlow Labs** es una startup de tecnología fundada hace 2 años en Bogotá. Desarrollan una plataforma SaaS de análisis de datos empresariales que permite a sus clientes corporativos cargar, procesar y visualizar grandes volúmenes de información financiera y operativa.

La empresa cuenta actualmente con **35 empleados** distribuidos así:

- **Equipo de Producto y Desarrollo** (12 personas): desarrollan y mantienen la plataforma.
- **Equipo de Datos e IA** (6 personas): diseñan los modelos analíticos y tienen acceso directo a las bases de datos de entrenamiento.
- **Equipo Comercial y Customer Success** (8 personas): gestionan clientes, contratos y demostraciones de la plataforma.
- **Equipo de Operaciones y TI** (4 personas): administran la infraestructura, servidores y accesos del sistema.
- **Equipo Legal y Finanzas** (3 personas): manejan contratos, facturación y cumplimiento regulatorio.
- **Directivos (C-Level)** (2 personas): CEO y CTO, con visibilidad global del negocio.

**Activos de información críticos de DataFlow Labs:**

| ID | Activo | Descripción |
|---|---|---|
| A1 | Base de datos de clientes | Nombres, contratos, datos de contacto, historial de compras |
| A2 | Código fuente de la plataforma | Repositorio Git con toda la lógica del producto |
| A3 | Datos financieros internos | Nómina, presupuestos, estados de resultados |
| A4 | Datos de entrenamiento de IA | Datasets cargados por clientes para entrenar modelos |
| A5 | Panel de administración del sistema | Consola de control de servidores, configuración y accesos |

| | | |
|---|---|---|
| A6 | Contratos y documentos legales | Acuerdos de confidencialidad, contratos con clientes y proveedores |
| A7 | Dashboard de métricas del negocio | KPIs de ventas, uso de la plataforma, retención de clientes |
| A8 | Sistema de tickets de soporte | Solicitudes e incidencias reportadas por clientes |

## CLASIFICACIÓN DE ACTIVOS

Para cada uno de los 8 activos listados anteriormente, completen la siguiente tabla asignando:

- **Nivel de clasificación:** Público / Interno / Confidencial / Crítico
- **Justificación breve:** ¿Por qué le asignaron ese nivel?
- **Impacto si se filtra:** Bajo / Medio / Alto / Catastrófico

| ID | Activo | Nivel de clasificación | Justificación | Impacto si se filtra |
|---|---|---|---|---|
| A1 | Base de datos de clientes | Crítico | Su exposición viola contratos y la regulación de protección de datos (personales y comerciales) | Catastrófico |
| A2 | Código fuente | Crítico | Es el núcleo del producto, su robo permite replicar la plataforma o explotar vulnerabilidades | Catastrófico |
| A3 | Datos financieros internos | Confidencial | Nómina y presupuestos son sensibles internamente, Información estratégica interna | Alto |
| A4 | Datos de entrenamiento de IA | Crítico | Son datos de clientes depositados bajo confianza, ventaja competitiva | Catastrófico |
| A5 | Panel de administración | Crítico | Acceso total a infraestructura, comprometer este activo compromete todos los demás | Catastrófico |
| A6 | Contratos y documentos legales | Confidencial | Sensibles para la relación comercial, pero no tan operacionalmente críticos como el código o los datos de clientes | Alto |
| A7 | Dashboard de métricas | Interno | Útil competitivamente, pero no catastrófico si se filtra, no contiene datos personales de clientes | Medio |
| A8 | Sistema de tickets de soporte | Confidencial | Puede contener información técnica sensible de los clientes y descripción de bugs o vulnerabilidades | Alto |

1. ¿Qué activo consideran el más crítico para la supervivencia del negocio y por qué?

R/ **Panel de administración**: Quien controla el panel de administración controla todos los demás activos. Un atacante con acceso a la consola puede leer A1, A2, A4, modificar configuraciones, crear y desactivar controles de seguridad. Es el punto de falla total del negocio.

## DEFINICIÓN DE ROLES Y PROPIETARIOS

Para cada activo, identifiquen quién debería ser el **Propietario** y quién el **Custodio**, **Usuarios** según los equipos descritos en el caso.

Recuerden:

- **Propietario:** quien tiene la responsabilidad de negocio sobre ese dato y decide quién puede acceder.
- **Custodio:** quien lo administra técnicamente (generalmente TI).
- **Usuario:** quien lo consulta o usa en su trabajo diario.

| ID | Activo | Propietario (equipo/cargo) | Custodio (equipo/cargo) | Usuarios típicos |
|---|---|---|---|---|
| A1 | Base de datos de clientes | Comercial/CS | Operaciones / TI | Comercial, Directivos |
| A2 | Código fuente | Desarrollo | Operaciones / TI | Desarrollo |
| A3 | Datos financieros internos | Legal/Finanzas | Operaciones / TI | Legal/Finanzas, CEO |
| A4 | Datos de entrenamiento de IA | Datos e IA | Operaciones / TI | Datos e IA, Desarrollo |
| A5 | Panel de administración | CTO | Operaciones / TI | Operaciones / TI, CTO |
| A6 | Contratos y documentos legales | Legal | Legal y Finanzas | Legal/Finanzas, CEO, Comercial |
| A7 | Dashboard de métricas | CEO/CTO | Operaciones / TI | Todos (lectura) |
| A8 | Sistema de tickets de soporte | Comercial/CS | Operaciones / TI | Comercial |

## TABLA DE CONTROL DE ACCESO (MATRIZ RBAC)

Usen el modelo **RBAC (Role-Based Access Control)** para diseñar la matriz de permisos de DataFlow Labs.

**Convención de permisos:**

- **L** = Solo lectura (can Read)
- **E** = Lectura y escritura (can Edit)
- **A** = Acceso total con administración (Admin)
- **—** = Sin acceso

Completen la siguiente matriz cruzando cada equipo con cada activo:

| **Activo → / Equipo ↓** | **A1 Clientes** | **A2 Código** | **A3 Finanzas** | **A4 Datos IA** | **A5 Panel Admin** | **A6 Contratos** | **A7 Métricas** | **A8 Soporte** |
|---|---|---|---|---|---|---|---|---|
| Desarrollo | — | E | — | L | — | — | L | L |
| Datos e IA | — | L | — | E | — | — | L | L |
| Comercial / CS | E | — | — | — | — | L | L | E |
| Operaciones / TI | — | L | — | — | A | — | L | L |
| Legal / Finanzas | — | — | A | — | — | A | L | — |
| CEO / CTO | L | L | L | L | L | L | A | L |

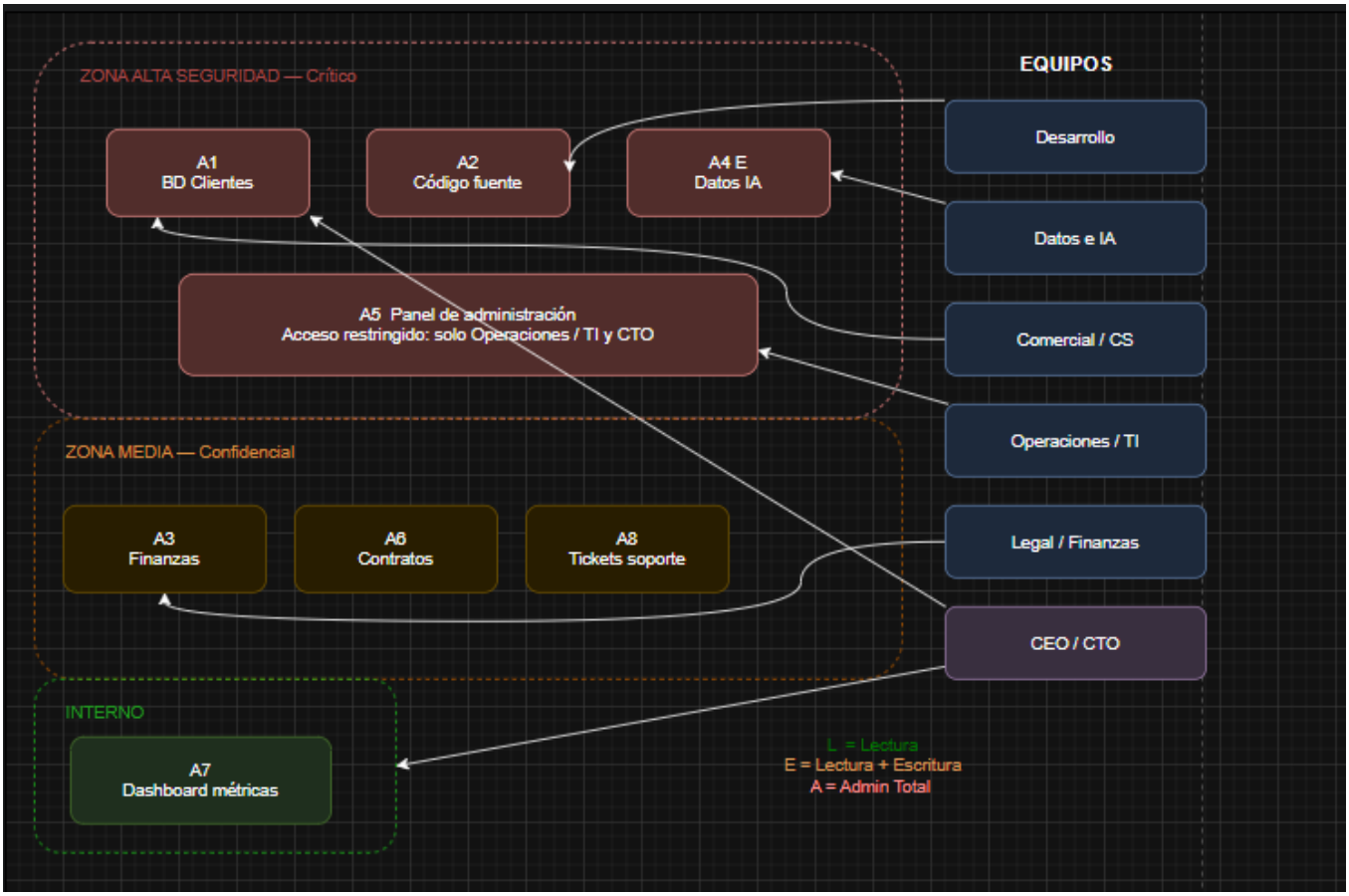
1. ¿Se aplico el principio de **privilegio mínimo**?
   R/ Sí. Cada equipo tiene acceso únicamente a los activos necesarios para sus funciones. Desarrollo no accede a nómina, finanzas no accede al panel de administración, comercial no accede al código fuente

2. ¿Debería el CEO tener acceso total a todos los activos?
   R/No. El CEO tiene una necesidad de visibilidad, pero no necesita capacidad de modificar el código, alterar configuraciones de servidores o editar bases de datos de clientes directamente. Darle acceso Admin a todos los activos viola el principio de mínimo privilegio y convierte la cuenta del CEO en un vector de ataque de altísimo impacto. Lo correcto es acceso de lectura sobre los activos estratégicos, y acceso administrativo del negocio, que es el activo de su responsabilidad directa.

## DIAGRAMA DEL ESQUEMA DE CONTROL DE ACCESO

Con base en la matriz que construyeron, elaboren un diagrama que represente visualmente el esquema de control de acceso de DataFlow Labs.

- El diagrama debe mostrar los activos A1 a A8 como bloques organizados según su nivel de clasificación.
- Los equipos y roles de la empresa se representan como entidades separadas que se conectan a dichos activos mediante flechas, indicando en cada flecha el tipo de permiso correspondiente (L, E o A).
- Finalmente, los activos clasificados como Críticos o Confidenciales deben agruparse dentro de una zona de alta seguridad que los separe visualmente del resto.




1. ¿Identificaron algún error o inconsistencia en su matriz que no habían notado antes?

   R/ Son posibles inconsistencias como el comercial con acceso excesivo a clientes (debiendo limitarse por clientes)

## ESCENARIOS DE AMENAZA

Evalúen los siguientes escenarios aplicados al contexto de DataFlow Labs. Para cada uno, respondan:

- **¿El esquema de control de acceso que diseñaron lo habría prevenido?**
  **Escenario1:** Sí, si la matriz RBAC hubiera estado implementada técnicamente. En el papel, Desarrollo no tiene acceso a A3 (Finanzas).

  **Escenario2:** No. La matriz define quién accede, pero no contempla qué pasa cuando alguien deja de trabajar en la empresa. El offboarding no estaba en el esquema.

  **Escenario3:** No. La matriz controla roles internos, pero no contempla que un empleado comparta sus credenciales con un externo. El eslabón débil fue humano, no técnico.

- **¿Qué control específico lo hubiera evitado o mitigado?**
  **Escenario1:** ACL que impidan físicamente que el rol Desarrollador lea carpetas o tablas de nómina. Sin implementación técnica, la política no vale nada.

  **Escenario2:** Proceso formal de inmediato al día de la renuncia: desactivación de cuenta e n directorio centralizado que propague la baja a todos los sistemas automáticamente. Tipo de control: preventivo.

  **Escenario3:** Dos controles combinados: a nivel técnico, row-level security en la base de datos. A nivel organizacional, política explícita de prohibición de compartir credenciales con consecuencias claras.

**Escenario 1 — El empleado curioso** Un desarrollador del equipo de producto nota que puede acceder al módulo de nómina dentro del sistema interno porque nadie configuró restricciones en ese directorio. Descarga el archivo de salarios de todos los empleados y lo comparte con un compañero.

- ¿Su matriz lo habría prevenido?

  Sí, si estuviera correctamente implementada. Según la matriz, el equipo de Desarrollo no tiene acceso a finanzas. El problema es que la restricción existía en el papel pero no estaba configurada *en el sistema*.

- ¿Qué control de acceso específico falla aquí?

  Control de acceso basado en roles (RBAC) no implementado a nivel de sistema de archivos o directorio. Las políticas de acceso existían de forma implícita, pero nunca se tradujeron en permisos técnicos efectivos en el servidor.

- ¿Qué corrección aplicarían?

  Aplicar ACL a nivel de directorio. Configurar los permisos del sistema operativo/servidor de modo que el rol "Desarrollador" no tenga permisos de lectura en el directorio /finanzas o la base de datos correspondiente. Adicionalmente, implementar monitoreo de acceso para detectar accesos inusuales.

**Escenario 2 — La cuenta olvidada** Una diseñadora UX trabajó 6 meses en DataFlow Labs y renunció. Tres meses después de su salida, su cuenta de usuario sigue activa. Un atacante externo que obtuvo sus credenciales por phishing accede al repositorio de código fuente usando esa cuenta.

- ¿Su esquema contempla la gestión del ciclo de vida de los usuarios?

  No de forma explícita. La matriz RBAC define quién tiene acceso, pero no establece el proceso de des aprovisionamiento cuando un empleado sale.

- ¿Qué proceso debería existir para evitar esto?

  Un procedimiento formal de offboarding que incluya, en el mismo día de la salida del empleado: desactivación inmediata de la cuenta en todos los sistemas, revocación de tokens

- ¿Qué tipo de control es este: preventivo, detectivo o correctivo?

  Este es principalmente un control preventivo (evita que la cuenta sea usada), pero también tiene componente detectivo si se implementan alertas de "login de cuenta inactiva hace X días".

**Escenario 3 — El cliente con demasiado acceso** Un cliente corporativo de DataFlow Labs contacta al equipo de Customer Success para solicitar ayuda con su dashboard. El asesor comercial, para agilizar el soporte, le comparte sus propias credenciales de acceso al panel de administración. El cliente, sin mala intención, navega por secciones a las que no debería tener acceso y descarga datos de otro cliente.

- ¿Qué principio de control de acceso se violó?

  Múltiples principios a la vez: el de separación de privilegios, el de cuentas individuales no compartir credenciales**,** y el de mínimo privilegio.

- ¿Qué mecanismo técnico y organizacional hubiera prevenido esta situación?

  A nivel técnico, un sistema controlado o un portal de cliente aislado donde el cliente solo ve sus propios datos mediante aislamiento de datos a nivel de base de datos,
  A nivel organizacional, una política explícita de prohibición de compartir credenciales, capacitaciones al equipo, y un canal de soporte técnico dedicado que no requiera acceso

directo a la plataforma de producción.

- ¿Quién es responsable del incidente: el asesor, la empresa, el cliente?

  La responsabilidad es compartida pero primariamente de la empresa. El asesor cometió una infracción a la política de seguridad (si existía) o actuó en ausencia de una política clara. La empresa falló al no tener controles técnicos que impidan compartir credenciales con terceros ni segregación de datos entre clientes. El cliente actuó de buena intención. Desde el punto de vista legal y regulatorio, la empresa responde ante el cliente cuya información fue expuesta, independientemente del error interno.